

Case: Mail n' Trail

04/22/2026

Executive summary

Given the credentials of johnd and the password of toor, we had to recover the username and password for the splunk system. To do this we downloaded and enabled a nmap scan of the server to discover that a few ports were open. We noticed that the 110 port was open meaning the email was in a dovecot pop3 port. We reenabled telnet using the command in cmd `dism /online /Enable-Feature /FeatureName:TelnetClient`. We then connected to the email using telnet `<server_ip> 110` receiving the message dovecot ok.

We enter in user johnd then pass toor to log into john's account. We enter list to see he has four messages; we then enter retr on 1-4 to find that it is on the fourth email which the credentials username admin and password CTF_Final! After that we enter `server_ip:8000` user the credentials and then get into splunk. We go under search & reporting and look around entering different search queries associated with malicious behavior. We enter `index=* login.failed` to see that there was an IP address attempting a brute force attack pushing username and passwords from 192.168.56.1.

We then changed the filter to `index=* 192.168.56.1 .failed` to see there was an attempted file download from a Pastebin website. Entering a few of the URLs we saw some saying "No, It's not it." and "downloading==➡ script.bat" we then found one called <https://pastebin.com/raw/0cs1NHvhit> which has a encoded base64 message `Q29uZ3JhdHMslHlvdSBoYXZlIGZpbmlzaGVkIENJVf9GSU5BTCBzdWNjZXNzZnVsbHk=` we then decode it to find Congrats, you have finished CIT_FINAL successfully which is the accepted flag ending the challenge.

Findings and Analysis

Finding	Finding Details	Description
Port	110	Port discovered open with pop3 dovecot allowing us mail access
Malicious connection	192.168.56.1	IP address attempting to brute force and download files in cowrie
Mail service port	Dovecot	Program where the mail files were held
Website attempting to download	https://pastebin.com/raw/0cs1NHvhit	Website where files that were trying to download from into honeypot
Congrats, you have finished CIT_FINAL successfully	Base 64 encoded flag	Flag encoded to successfully finish the challenge.

Tools and Technologies Used

- Nmap: command line tool that is used to display connections and open ports, commonly used for security auditing. I used nmap to figure out which ports were open when trying to find the email server
- telnet: a communication command used to access services in plaintext and is not encrypted. Used to access the email account
- Splunk: A SIEMS log program

Investigation Process

1. I started this investigation by trying to figure out what mail server was used. I downloaded and used nmap to scan the server IP address to see that it had several open ports, one being port 110 POP3 dovecot. Knowing this is a mail program, I

attempted to connect to it

```
Scanning ctf-splunk-machine (10.0.167.61) [1000 ports]
>discovered open port 995/tcp on 10.0.167.61
>discovered open port 25/tcp on 10.0.167.61
>discovered open port 22/tcp on 10.0.167.61
>discovered open port 110/tcp on 10.0.167.61
>discovered open port 3389/tcp on 10.0.167.61
>discovered open port 8089/tcp on 10.0.167.61
>discovered open port 8000/tcp on 10.0.167.61
>discovered open port 514/tcp on 10.0.167.61
```

2. I reinstated the use of telnet temporarily to search the email for the username and password for the splunk system, sorting through all 4 emails we find that the username and password for splunk are in there.

```
retr 4
+OK 869 octets
Return-Path: <root@corporate.com>
X-Original-To: johnd@corporate.com
Delivered-To: johnd@corporate.com
Received: by splunk-server.ec2.internal (Postfix, from userid 0)
        id 914CC1B9364; Mon, 19 Aug 2024 10:30:50 +0000 (UTC)
Subject: We launched Splunk!
Message-Id: <20240819103050.914CC1B9364@splunk-server.ec2.internal>
Date: Mon, 19 Aug 2024 10:30:50 +0000 (UTC)
From: root <root@corporate.com>

Hey there,

We wanted to call your attention to our new SIEM product we released overnight.
Using this new feature, you'll be able to investigate for suspicious events.
If you have any questions about the best ways to use Splunk, please feel free to give us a call at +1-202-555-0128.

To use Splunk, navigate to the following URI:
http://[SERVER-IP]:8000/

The credentials are as follows:
username: admin
password: CTF_Final!

Thank you,
Admin
```

3. We then go to the browser and enter <server_ip>:8000 to access splunk services
4. We go to search and reporting and enter our first command index=*
5. Seeing this returns a lot of noise we attempt common keywords for malicious activities or strange events.
6. We enter index=* login to see if anything returns to see that there is an IP address possibly attempting to brute force with several different username and password fail attempts.
7. We narrow our search to check for failed events only by entering index=* 192.168.56.1 .failed to see several failed events including a failed download attempt.
8. After this we narrow the search to index=* 192.168.56.1 .failed.download

9. We then see several attempts to download files to the server

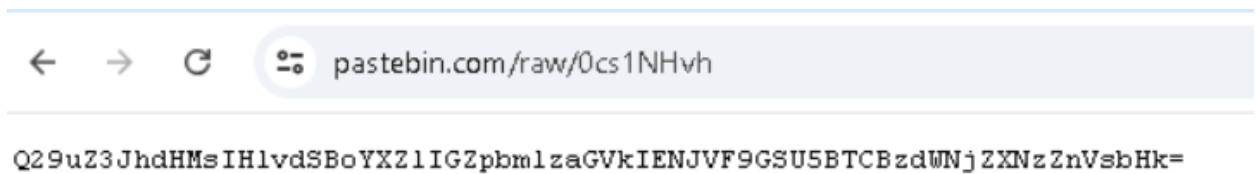
```
,,,,,,,,,,,,,"{"eventid":"cowrie.session.file_download.failed","url":"https://pastebin.com/raw/jpSBiHjC","message":"Attempt to download file(s) from URL (https://pastebin.com/raw/jpSBiHjC) failed","sensor":"mail.corporate.com","timestamp":"2020-02-17T07:27:38.269025Z","src_ip":"192.168.56.1","session":"a8e3f8b33ca5"},"2020-02-17T07:27:38.000-0400",,,,,,,,,,,,,,"mail.corporate.com",,,,main,,,,1,,,,,,,,,,,,,"{""""""..","""":"//.//","""":"__()__(:/.//)_","""":"",,,,,,,,,,,,,"/home/cowrie/cowrie/var/log/cowrie/cowrie.json", "_json", "mail.corporate.com",,,,,,,,,,,,,,
host = mail.corporate.com | source = Server.csv | sourcetype = csv
```

10. When entering the paste bin URL in a secure environment for testing, we find several items including “No, It’s not it.” and “Downloading ==> script.bat” this would be a malicious event if true, downloading a malicious script file.



11. After that we find one that is

Q29uZ3JhdHMslHlvdSBoYXZlIGZpbmlzaGVkIENJVf9GSU5BTCBzdWNjZXNzZnVsbHk=



12. We test this and realize it is encoded in Base64, using an online decoder, we then discover it translates to Congrats, you have finished CIT_FINAL successfully. Thus, finishing the lab and capturing the flag.

Recommendations

1. Require that admins save user and password in secure encrypted environments
2. As a SOC analyst, I would implement a quick view dashboard to enable faster responses opposed to sorting through noise.